

QA LEADERSHIP ACADEMY

AI Risk Assessment

A structured way to assess and mitigate the risks of a specific AI use in QA before you rely on it.

Purpose

This instrument assesses the risk of a specific AI use in QA across the dimensions that actually cause harm — hallucination, data privacy and PII, intellectual-property and source-code exposure, incorrect or misleading tests, over-reliance and skills erosion, and vendor lock-in. For each it captures likelihood, impact and a concrete mitigation, and it insists on a named human accountable for the output. It is a professional risk tool, not legal advice.

DEFER TO YOUR REAL POLICIES

This worksheet does not replace your organisation's data-protection, security or legal policies. Where a risk touches personal data, security or contracts, defer to those policies and the people who own them. When in doubt, treat the answer as "not yet", not "probably fine".

When to use it

- Before adopting any AI use case that the Use-Case Matrix flagged as high-risk.
- To bring an existing informal AI use under control and document its mitigations.
- As a required gate before an AI Pilot starts, and again before scaling it.

Instructions

1. State the specific use case and exactly what data or artefacts would be sent to the tool.
2. For each risk dimension, rate likelihood (L/M/H) and impact (L/M/H) for your context.
3. Write a concrete mitigation for every medium or high cell — not "be careful", but a specific control.
4. Name the accountable human who reviews and signs off the AI output; accountability cannot sit with the tool.
5. Record a decision: proceed, proceed with controls, or do not proceed — and defer any legal/privacy question to the relevant policy owner.

Worked example

Assessing the informal Northstar behaviour — testers pasting code and tickets into public AI tools with no policy — for the specific use "generate automation code by pasting application source into a public AI tool":

Risk	Likelihood	Impact	Mitigation	Accountable
Hallucination (plausible but wrong output)	High	Medium	All generated code and tests reviewed and run before use; never trusted unread	Reviewing engineer
Data privacy / PII exposure	Medium	High	No customer or production data pasted; use synthetic data; defer to the data-protection policy	QA lead + DPO/policy owner
IP / source-code exposure	High	High	No proprietary source pasted into public tools; use only an approved, contractually safe tool; defer to security policy	Engineering manager + security
Incorrect / misleading tests	Medium	High	Generated tests peer-reviewed for real assertions, not tautologies that always pass	Reviewing engineer
Over-reliance / skills erosion	Medium	Medium	AI drafts, humans decide; juniors still learn the reasoning; no unreviewed acceptance	QA lead
Vendor lock-in	Low	Medium	Keep prompts/outputs portable; avoid deep proprietary integration until value is proven	QA lead

Decision for this specific use: do not proceed via public tools. The IP and PII exposure sit at high impact with realistic likelihood, and there is no policy in place — so the responsible action is to pause the informal behaviour, agree an approved tool and a no-source/no-customer-data rule with security and the data-protection owner, and only then re-assess. The lower-risk uses (drafting test ideas from acceptance criteria) can proceed with human review in the meantime.

Blank reusable version

Risk	Likelihood (L/M/H)	Impact (L/M/H)	Mitigation (concrete)	Accountable human
Hallucination				
Data privacy / PII				
IP / source-code exposure				
Incorrect / misleading tests				
Over-reliance / skills erosion				
Vendor lock-in				
Overall decision			Proceed / proceed with controls / do not proceed	

Common mistakes

COMMON MISTAKES

Assessing "AI" in general rather than one specific use and its exact data flow; writing woolly mitigations like "be careful" instead of concrete controls; leaving accountability with the tool rather than a named person; giving legal or privacy rulings yourself instead of deferring to the policy owner; and assessing once, then never revisiting as the use scales.

How to interpret the results

- A single high-impact / high-likelihood cell with no real mitigation is a "do not proceed", regardless of the other rows.
- If a mitigation depends on a policy that does not yet exist, the honest status is "blocked pending policy", not "mitigated".
- Over-reliance is the quiet one — low drama, but it erodes your team's skill over time, so treat its mitigation seriously.
- Re-assess at scale: a risk that is acceptable for one tester experimenting can become unacceptable across a whole team.

INSIDE STLC PRO TIP

The most important cell is the accountable human, not the risk score. AI can draft, suggest and accelerate, but a person always owns the output that ships. Make that explicit on every assessment and you turn AI from a governance headache into a tool your organisation can trust you with.